

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Operator of private transfer rail or customer transfer product
DPO or similar function	Controller DPO or privacy contact
Repository evidence	Consumers/ONEWAY_WIKI; wireClient.js; shyware/embodiments/shywire; patent.

Name of the Processing

Internal name: Shyware Private Value Transfer DPIA

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category	Sensitivity
1	Transfer record	Asset id, amount, sender/recipient commitments, timestamp	Financial
2	Account commitment	Pseudonymous sender or recipient commitment	Medium
3	Eligibility/KYC/KYB status	Compliance status, sanctions/fraud screening, entity verification	High
4	Recovery/reconcile record	Off-chain mapping for recoverable posture or lawful attribution	High

Purposes of the Processing Enable private value transfer, audit of conservation invariants, fraud prevention, recovery, and lawful compliance workflows.

Nature, Scope and Context Value transfer can involve financial data, fraud/sanctions controls, disputes, and regulated payment or asset-transfer obligations. Canonical-state privacy controls must be balanced against compliance and lawful attribution requirements.

ANALYSIS OF THE PROCESSING

Lawfulness and Minimisation

Customer controllers must determine financial-services, AML/KYC, consumer-protection, and transfer-law obligations. Shyware should avoid claiming that canonical-state unlinkability eliminates regulated reporting or sanctions obligations.

Mainhub Patent Alignment

The Mainhub patent architecture can reduce canonical-state linkage between identity/account commitments and transfer payload records. It does not remove obligations to identify parties, preserve financial records, screen sanctions, detect fraud, or provide lawful reporting where required. Any value-transfer deployment must treat compliance hooks, off-chain reconciliation, wallet/account proof, and dispute controls as residual risk surfaces.

Authority Partition This is a count-match embodiment. Four structurally separated parties are required:

Authority	Role
Auth (Cognito)	Account layer; always required; gates
IDV/KYC (Ditit)	Performs KYC/AML compliance veri
Enrollment/eligibility authority (enrolling bank or financial institution)	Determines whether KYC-verified use
Reconciling authority	Off-chain linkage store + sealer keys

Dual co-authorization enforcement (Claim 2): The validation layer must reject single-signature rescission transactions. Both the enrollment authority and reconciling authority co-signatures are required before any canonical deletion. **VERIFIED (run 26369476939):** *DUAL_COSIG section passes 379/379 — unauthenticated + valid token → 401; authenticated + no token → 400; both co-signatures → 200, countMatch preserved.*

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The private value transfer pattern may be proportionate where transfer privacy, conservation auditability, fraud prevention, dispute handling, and legally required reporting can coexist. Protected linkage and reveal workflows should be limited to compliance, dispute, fraud, user recovery, or legally required reporting. Production should wait until regulated-reporting posture, payment/settlement flow, retention, adverse-action, and lawful-access policies are fixed.

RISK ASSESSMENT AND MANAGEMENT

#	Risk	Required Follow-up
1	Financial profiling or transfer deanonymization	Scope commitments and minimize off-chain linkage
2	Compliance failure	Map AML/KYC/sanctions obligations per launch jurisdiction
3	Fraud or unauthorized transfer	Review account auth, wallet proof, and dispute controls
4	Recovery authority overreach	Define lawful-access, dual-control, and audit logs

DPIA Audit Findings

This DPIA is the audit record for private value transfer deployments. Before production, the DPIA must identify the provider partition across KYC/KYB or wallet provider, payment/settlement provider, protected linkage store, reconciling authority, canonical commit authority, sanctions/fraud provider, and telemetry/support providers. Canonical-state unlinkability does not reduce AML, sanctions, fraud, reporting, dispute, tax, or consumer-protection obligations. The software evidence for the core kernel may be complete while legal basis, regulated-reporting posture, recovery/reveal, retention, and adverse-action controls still need to be fixed for this domain.

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** (`patent/mainhub/dpia/source/COM` published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key` $\neq$ `reconciling_authority_key` $\neq$ `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment

The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while financial-regulatory, payment/settlement, fraud, dispute, wallet/account, or lawful-reporting choices still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
AML/sanctions reporting failure	KYC/KYB review, sanctions controls, reporting policy, and audit logs
Financial transfer exposure	Payment minimization, tokenization, retention limits, and access controls
Fraud or dispute handling overreach	Typed adverse actions, human review, audit logs, and appeal workflow

Risk	Additional Measures Applied
Wallet/account linkability	Scoped commitments, wallet minimization, and provider partitioning
Provider consolidation	Provider matrix for KYC/KYB, payment, sanctions/fraud, linkage, recon

INVOLVEMENT OF INTERESTED PARTIES

Privacy counsel, financial-regulatory counsel, payment/settlement stakeholders, fraud/compliance teams, security, and customer DPO teams should review this DPIA before production. Data subject or customer representative consultation may be appropriate where consumer transfers, adverse action, or dispute outcomes are material.

CONCLUSION AND DECISION

Draft decision: Separate DPIA and financial-regulatory review required before launch.

Regulatory and Deployment Context Annexes

Annex A — Deployment Context Variants

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
Stablecoin transfers (Circle USDC)	OFAC sanctions exposure; AML transaction monitoring	FinCEN BSA; OFAC SDN list; EU AMLD6; FATF Travel Rule	Issuer reconcile authority (Circle read-only) required for AML/OFAC compliance; Travel Rule metadata for transfers above \$3,000 (US) / €1,000 (EU)
Cross-border remittances	FATF Travel Rule: originator and beneficiary information must accompany transfers	FATF Recommendation 16; EU Transfer of Funds Regulation (TFR) 2023	TFR requires originator IBAN/name and beneficiary IBAN/name to travel with transfers; shywire's structural anonymity applies at the canonical layer; TFR data must be preserved in the reconciling authority and disclosed to obligated entities

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
Consumer money transfers	Consumer protection; dispute resolution; chargeback rights	EU Payment Services Directive 2 (PSD2); US Regulation E (Electronic Fund Transfer Act); CFPB remittance rules	Error resolution process required; 30-day dispute window; disclosure of transfer fees and exchange rates before initiation
B2B commercial payments	KYB (know your business) requirements; sanctions screening at entity level	FinCEN CDD Rule (beneficial ownership); EU AMLD5 beneficial ownership register	UBO verification before account creation; entity-level sanctions screening; transaction monitoring for structuring patterns

Annex B — AML/CFT and FATF Travel Rule

shywire-v1’s structural anonymity at the canonical layer is compatible with AML/CFT compliance only because the issuer (Circle or equivalent) retains `reconcile_authority: issuer_read_only` access to the off-chain linkage store. This design deliberately preserves the regulatory surveillance capability required by FATF Recommendations 10 and 16:

- **FATF Travel Rule (R. 16):** Originator and beneficiary information must “travel” with virtual asset transfers above the threshold. In the shywire architecture, this information is in the reconciling authority’s off-chain store (not in canonical state). The issuer’s read-only access to the reconciling authority satisfies R. 16 if the issuer is itself a registered VASP and has entered Travel Rule data-sharing arrangements with counterparty VASPs.
- **EU Transfer of Funds Regulation (TFR, 2023):** Applies to crypto-asset transfers from 2024. Requires PSPs/CASPs to collect and transmit payer and payee information. shywire’s off-chain linkage store holds this data; the issuer reconcile authority can extract it for TFR compliance purposes.
- **US Bank Secrecy Act / FinCEN:** Money Services Businesses (MSBs) must register with FinCEN and implement AML programs. If the operator is an MSB, the shywire reconciling authority must support SAR and CTR filing capability.

Annex C — Money Transmitter Licensing

- **United States:** Money transmission is regulated at the state level. 49 states require a money transmitter licence (MTL) or equivalent for businesses that transmit money on behalf of others. Operating shywire as a consumer-facing transfer service without state MTLs is an enforcement risk. *Stablecoin wrapper mode* (`provider: circle_usdc`) with

Circle as the licensed issuer may exempt the operator from MTL requirements if Circle's licence coverage applies — counsel review required per state.

- **European Union:** Payment Institution (PI) or Electronic Money Institution (EMI) licence required under PSD2 for payment services. MiCA licence required for issuance of asset-referenced or e-money tokens.
- **UK:** FCA registration as an EMD Agent or PI Authorisation; cryptoasset registration under the MLRs.